Day 3: Image Management & Security

---

1. Docker Image Tagging, Storage, and Reuse

Definition

Docker image tagging is the process of assigning a readable identifier (name:tag) to an image for versioning, tracking, and reuse.

Image Tag Format

<repository>/<image-name>:<tag>

Example:

myapp:v1

myapp:latest

Tagging Commands

```
docker build -t myapp:v1 .
```

```
docker tag myapp:v1 myrepo/myapp:v1
```

Best Practices

- Avoid using latest in production
- Use version-based tagging (v1, v2, v1.0.1)
- Include environment tags (dev, prod)

Image Storage

Images can be stored in:

- Local Docker daemon
- Public registries (Docker Hub)
- Private registries (Artifact Registry)

Scenario

Multiple versions of application

Problem:

- Developers overwrite latest image

Solution:

- Use version tagging

Result:

- Easy rollback and traceability

Case Study

Microservices Deployment

- Each service tagged as:
  - user-service:v1
  - payment-service:v2

Result:

- Independent deployments
- Version control across services

---

2. Google Artifact Registry

Definition

Google Artifact Registry is a fully managed service to store and manage container images and other artifacts securely.

Key Features

- Private image storage
- Regional repositories
- Integration with GKE and Cloud Run
- IAM-based access control

Repository Format

<region>-docker.pkg.dev/<project-id>/<repo>/<image>

Example:

asia-south1-docker.pkg.dev/my-project/my-repo/myapp:v1

Scenario

Enterprise needs private image storage

Problem:

- Public registry is insecure

Solution:

- Use Artifact Registry

Result:

- Secure, controlled access

Case Study

FinTech Organization

- Stores images in private registry
- Uses IAM roles for access

Result:

- Secure image distribution
- Compliance with security standards

---

3. Image Vulnerability Scanning

Definition

Scanning container images to detect known vulnerabilities in OS packages and dependencies.

Tools

1. Trivy

- Open-source vulnerability scanner

Command:

trivy image myapp:v1

---

2. GCP Built-in Scanning

- Automatically scans images in Artifact Registry

Types of Vulnerabilities

- OS-level vulnerabilities
- Library/package vulnerabilities
- Misconfigurations

Scenario

Production image contains outdated library

Problem:

- Security risk

Solution:

- Run vulnerability scan
- Update dependencies

Result:

- Secure image deployment

Case Study

Healthcare Application

Problem:

- Image contains vulnerable OpenSSL version

Solution:

- Scan using Trivy
- Update base image

Result:

- Compliance with security standards

---

4. Secure Image Distribution and IAM Roles

Definition

Controlling who can push, pull, and manage container images using IAM roles.

Key IAM Roles

Role	Permission
Artifact Registry Reader	Pull images
Artifact Registry Writer	Push images
Artifact Registry Admin	Full control

Secure Practices

- Use private repositories
- Restrict access using IAM
- Avoid exposing images publicly
- Use service accounts for automation

Scenario

Unauthorized user accessing images

Problem:

- Security breach

Solution:

- Restrict access using IAM roles

Result:

- Controlled access

Case Study

Enterprise CI/CD Pipeline

- CI system uses service account
- Only pipeline can push images

Result:

- Secure and automated deployment

---

5. Hands-On: Push Images to Artifact Registry & Run Security Scans

---

Step 1: Authenticate with GCP

```
gcloud auth login
gcloud config set project <project-id>
```

Step 2: Create Repository

```
gcloud artifacts repositories create my-repo \
  --repository-format=docker \
  --location=asia-south1
```

Step 3: Configure Docker Authentication

```
gcloud auth configure-docker asia-south1-docker.pkg.dev
```

Step 4: Tag Image

```
docker tag myapp:v1 asia-south1-docker.pkg.dev/<project-id>/my-repo/myapp:v1
```

Step 5: Push Image

```
docker push asia-south1-docker.pkg.dev/<project-id>/my-repo/myapp:v1
```

Step 6: Scan Image (Trivy)

```
trivy image asia-south1-docker.pkg.dev/<project-id>/my-repo/myapp:v1
```

Step 7: View Scan in GCP Console

- Navigate to Artifact Registry
- Open image → Security insights

End-to-End Case Study (Day 3 Summary)

Scenario: Secure Image Management in Enterprise

Problem:

- No version control
- Public image exposure
- Security vulnerabilities

Solution

1. Tag images properly
2. Store in Artifact Registry
3. Scan images for vulnerabilities
4. Use IAM for secure access

Result

- Secure image storage
- Controlled access
- Reduced vulnerabilities
- Better compliance